

Security incident report

Section 1: Identify the network protocol involved in the incident

The network protocol involved in this incident is HTTP (Hypertext Transfer Protocol). HTTP uses the established TCP connection to request a webpage. The tcpdump log shows HTTP GET requests to yummyrecipesforme.com and later to greatrecipesforme.com after the browser was redirected. This identifies HTTP as the protocol used to request webpages from both websites.

Section 2: Document the incident

The cybersecurity team identified a brute-force attack where the attacker repeatedly entered several known default passwords in order to gain admin access. This attack succeeded because the admin account still used its default password and there were no controls preventing repeated attempts. The attacker then embedded a JavaScript function into the website's source code that prompted visitors to download and run a file upon visiting the website. After embedding the malware, the attacker changed the password to the administrative account. The website owner was unable to log into the admin panel and contacted the hosting provider.

yummyrecipesforme's helpdesk was alerted to the incident because several customers complained by email that the company's website had prompted them to download a file to access free recipes. The customers claimed that after running the file, their browsers were redirected to greatrecipesforme.com and their computers began running more slowly. The senior analyst's source-code review found added JavaScript that prompted the download. Analysis of the downloaded file also found a script that redirected visitors' browsers to greatrecipesforme.com.

To investigate the incident, the cybersecurity analyst created a sandbox environment to observe the suspicious website behaviour. Using the network protocol analyser tcpdump, the analyst captured network traffic while visiting yummyrecipesforme.com. Once the website had loaded, the analyst was prompted to download an executable file to update their browser. They accepted the download and allowed the file to run. The browser then redirected the analyst to a different URL, greatrecipesforme.com, which the scenario identifies as containing malware. The tcpdump log showed that another DNS request was made for greatrecipesforme.com, and the DNS server returned 192.0.2.172. The log then showed a TCP connection and an HTTP request to the second website.

Section 3: Recommend one remediation for brute force attacks

The attacker gained access to the system using an old default password which enabled them to reset the password. As a result the owner was unable to log in. The attack highlighted a vulnerability therefore it's important that we prevent any old passwords from being used again. The team also recommends implementing stronger passwords that use at least 16 characters and are completely random. Stronger passwords with random characters provide better protection from incidents such as brute force attacks. Lastly as an extra preventative measure, would be to enable 2FA (two-factor authentication). 2FA requires 2 forms of identification. A password and a one-time passcode (OTP) being sent to their email or phone. The user will have to confirm their identity using their login credentials in order to gain access to the system. 2FA strengthens the systems security because even if a malicious actor guesses the password correctly they will still require the extra form of identification in order to gain access to the system.